

Security+ 2.4 · Viruses & Worms

Mestre CyberSec · Aula 2.4 — Viruses & Worms (5:54) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Vírus PRECISA de hospedeiro (arquivo) e ação do usuário pra propagar. Worm SE-PROPAGA SOZINHO pela rede (sem hospedeiro). Fileless roda direto na RAM — não toca no disco. Defesa: patch (worm explora vulnerabilidade de rede), EDR com behavioural detection.

💡 Highlights que a prova CompTIA cobra

- Vírus: precisa de hospedeiro + usuário. Worm: se-propaga sozinho
- Fileless: nenhum arquivo no disco — detectado pela memória/log, não hash

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'self-propagates through the network without user action' = worm

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Vírus (N/A)

Código malicioso que se anexa a um arquivo hospedeiro ou executável e requer ação do usuário para se replicar e se espalhar.

 **Armadilha CompTIA:** *Precisa de hospedeiro + ação do usuário. Se a questão enfatiza propagação sem interação, não é vírus.*

• Verme (N/A)

Malware auto-replicante que se espalha pela rede sem arquivo hospedeiro e sem ação do usuário, frequentemente explorando vulnerabilidades.

 **Armadilha CompTIA:** *Gatilho: 'self-propagates through the network without user action' = worm. Não precisa de hospedeiro.*

• Malware sem arquivo (N/A)

Malware que executa na memória e não grava arquivo no disco, dificultando a detecção por hash.

 **Armadilha CompTIA:** *Detecção via memória, logs e comportamento; não depende de hash de arquivo.*

• Detecção e Resposta em Endpoints (EDR)

Solução de segurança que monitora a atividade do endpoint e usa detecção comportamental para identificar e responder a ações maliciosas, incluindo ataques sem arquivo.

 **Armadilha CompTIA:** *Defesa chave contra fileless e worms: comportamento, telemetria e resposta, não apenas assinaturas.*

• Gerenciamento de Patches (N/A)

Processo de aplicar atualizações de software para corrigir vulnerabilidades que worms costumam explorar para propagação em rede.

 **Armadilha CompTIA:** *Defesa primária contra worms: corrigir a vulnerabilidade de rede explorada. Patch antes do ataque.*

• Auto-propagação (N/A)

Capacidade de malware se espalhar de forma autônoma sem interação do usuário, característica de worms.

 **Armadilha CompTIA:** *Palavra-chave para worm. Vírus não se auto-propaga sem ação do usuário.*

• Hospedeiro (N/A)

Arquivo, executável ou componente do sistema que um vírus infecta e usa para se replicar e se espalhar.

 **Armadilha CompTIA:** *Vírus PRECISA de hospedeiro; worm NÃO. Se a questão menciona arquivo infectado, pense em vírus.*

• Carga útil (N/A)

Ação ou código malicioso entregue pelo malware, como destruição de dados, criptografia ou instalação de backdoor.

 **Armadilha CompTIA:** *Payload é o que o malware faz; propagação é como ele se espalha. Não confunda com o vetor.*

Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um funcionário do financeiro abre uma planilha anexada a um e-mail de fornecedor. A planilha contém uma macro que se copia para o modelo normal do usuário e infecta outros arquivos .xlsx que o funcionário edita depois. Ela não se espalha para outros computadores a menos que esses arquivos infectados sejam abertos neles. Qual tipo de malware melhor se encaixa nesse comportamento?

- A) Vírus
- B) Worm
- C) Malware fileless
- D) Rootkit

QUESTÃO 2 · CENÁRIO DE EXAME

Uma rede hospitalar tem vários servidores Windows sem patch. Um programa malicioso varre a TCP 445, explora SMB, copia-se para todos os servidores alcançáveis e continua a varredura a partir de cada host recém-infectado. Nenhum usuário abre arquivo ou clica em link. Qual tipo é?

- A) Vírus
- B) Worm
- C) Malware fileless
- D) Trojan

QUESTÃO 3 · CENÁRIO DE EXAME

Durante a resposta a incidentes, um analista descobre que um documento de phishing iniciou o PowerShell, que injetou código em um processo em execução e executou comandos apenas em memória. Nenhum executável malicioso foi gravado no disco, e a atividade desapareceu após reiniciar. Qual técnica de malware é descrita?

- A) Malware fileless
- B) Worm
- C) Vírus de setor de inicialização
- D) Vírus multipartite

QUESTÃO 4 · CENÁRIO DE EXAME

Um fornecedor lança um patch crítico para uma falha de execução remota de código em um serviço de rede. Até o patch ser aplicado, um worm pode comprometer qualquer servidor alcançável sem patch, sem interação do usuário. Qual controle reduz mais diretamente o risco da propagação inicial desse worm?

- A) Gestão de patches
- B) Filtragem de anexos de e-mail
- C) Treinamento de conscientização de segurança
- D) Criptografia de disco completo

QUESTÃO 5 · CENÁRIO DE EXAME

Um SOC quer detectar ataques que usam PowerShell, WMI e injeção de processo, não deixam arquivos no disco e se comportam de forma diferente de assinaturas conhecidas. Qual tecnologia é mais adequada para essa detecção?

- A) Antivírus baseado em assinaturas
- B) EDR com detecção comportamental
- C) Prevenção de perda de dados
- D) Criptografia de disco completo

QUESTÃO 6 · CENÁRIO DE EXAME

Uma amostra de malware portátil se copia para unidades USB e compartilhamentos de rede mapeados. No entanto, ela só executa quando um usuário clica duas vezes em um arquivo infectado, e não explora nenhum serviço de rede para se espalhar sozinha. Qual tipo é mais provável?

- A) Worm
- B) Vírus
- C) Malware fileless
- D) Ransomware

QUESTÃO 7 · CENÁRIO DE EXAME

Um surto de malware criptografa arquivos em muitos servidores. A análise forense mostra que o componente inicial explorou uma vulnerabilidade de servidor web, varreu a rede interna e se copiou para outros hosts. Após se espalhar, baixou um payload de ransomware. Como se chama o componente auto-propagante?

- A) Vírus
- B) Worm
- C) Malware fileless
- D) Adware

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista de malware examina uma amostra que anexa seu código a um executável de aplicativo legítimo. O aplicativo ainda funciona, mas quando um usuário desavisado o inicia, o malware executa e infecta outros executáveis no mesmo sistema. Qual classificação de malware corresponde a essa amostra?

- A) Vírus
- B) Worm
- C) Malware fileless
- D) Spyware

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa quer reduzir o risco de vírus de macro entregues por documentos. Os usuários frequentemente recebem arquivos do Office de parceiros externos. Qual controle é mais eficaz para impedir que a macro execute quando um usuário abre um documento?

- A) Desativar macros por padrão e permitir apenas macros assinadas de editores confiáveis
- B) Instalar criptografia de disco completo em todos os notebooks
- C) Bloquear todo o tráfego DNS de saída
- D) Habilitar segurança de porta nos switches de acesso

QUESTÃO 10 · CENÁRIO DE EXAME

Uma equipe de resposta a incidentes confirma que um worm explorou um serviço sem patch e então instalou um minerador de criptomoeda em cada host infectado. Qual termo melhor descreve o minerador de criptomoeda nessa cadeia de infecção?

- A) Payload
- B) Host
- C) Worm
- D) Malware fileless

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Vírus

É um vírus porque exige um arquivo hospedeiro (a planilha/modelo) e ação do usuário (abrir/editar o arquivo) para se propagar. Ele não se auto-propaga pela rede como um worm. Malware fileless executaria na memória sem gravar arquivo, e um rootkit foca em ocultação/persistência, não nesse padrão de propagação.

Questão 2: Alternativa B — Worm

É um worm porque se auto-propaga pela rede explorando uma vulnerabilidade de serviço, sem precisar de arquivo hospedeiro ou ação do usuário. Um vírus precisa de execução pelo usuário e arquivo hospedeiro; malware fileless roda em memória, mas não se auto-propaga necessariamente; um Trojan se disfarça de software legítimo e não se espalha automaticamente assim.

Questão 3: Alternativa A — Malware fileless

É malware fileless porque o código malicioso roda na RAM e não grava um executável persistente no disco. Worms se auto-propagam pela rede, enquanto vírus de setor de inicialização e multipartite envolvem infecção de disco/setor de boot e propagação baseada em arquivo.

Questão 4: Alternativa A — Gestão de patches

A gestão de patches fecha diretamente a vulnerabilidade do serviço de rede que o worm explora. Filtragem de e-mail e treinamento ajudam contra ameaças conduzidas por usuário, como vírus, e criptografia de disco protege dados em repouso, mas não impede exploração remota.

Questão 5: Alternativa B — EDR com detecção comportamental

EDR com detecção comportamental é melhor porque monitora comportamento de processos, atividade de memória e execução de linha de comando, podendo revelar ataques fileless mesmo sem arquivo malicioso gravado. Antivírus por assinatura pode não detectar comportamento novo ou apenas em memória; DLP e criptografia de disco não detectam injeção de processo ou abuso de PowerShell.

Questão 6: Alternativa B — Vírus

É mais provável um vírus porque se espalha por arquivos e exige ação do usuário para executar. Embora alcance USB e compartilhamentos, não se auto-propaga explorando serviços de rede, que é o comportamento definidor de um worm. Malware fileless não dependeria de arquivos infectados, e ransomware descreve um payload/impacto, não o método de propagação.

Questão 7: Alternativa B — Worm

O componente auto-propagante é um worm porque se espalha pela rede explorando uma vulnerabilidade e não precisa de arquivo hospedeiro ou ação do usuário. Ransomware é o payload entregue após a propagação. Um vírus exigiria execução pelo usuário e arquivo hospedeiro, e malware fileless é definido por execução apenas em memória, não por auto-propagação.

Questão 8: Alternativa A — Vírus

Corresponde a um vírus porque usa um executável legítimo como hospedeiro, modifica-o e depende de o usuário iniciar o programa infectado para executar e se espalhar para outros arquivos. Um worm se espalharia sem ação do usuário ou arquivo hospedeiro, malware fileless evitaria arquivos em disco, e spyware descreve um payload de coleta de dados, não esse método de infecção.

Questão 9: Alternativa A — Desativar macros por padrão e permitir apenas macros assinadas de editores confiáveis

Desativar macros por padrão e permitir apenas macros assinadas impede diretamente que código de macro não confiável execute quando um documento é aberto, bloqueando a rotina de infecção do vírus. Criptografia de disco, bloqueio de DNS e segurança de porta de switch não tratam a execução de macros em documentos.

Questão 10: Alternativa A — Payload

O minerador de criptomoeda é o payload porque é a ação ou código malicioso entregue após o worm obter acesso e se espalhar. O host é o sistema infectado ou o arquivo que carrega um vírus, o worm é o mecanismo auto-propagante, e malware fileless não é indicado pelo cenário.

